Lab9-CTF

Date: December 19, 2024

CTF起源于1996年DEFCON全球黑客大会，用以代替黑客通过发起真实攻击进行技术比拼。现今一般代指网络安全竞赛

Press Space for next page →

CTF比赛模式

解题模式、攻防模式、渗透

解题模式	线上选拔， 参赛队伍可通过互联网或现场网络参与，通过在线环境交互或文件离线分析，解决网络安全按技术挑战，获取相应分值，与ACM竞赛类似。 大致流程是，**从比赛环境中得到遗传具有一定格式的字符串或者其他内容（称为flag），提交给主办方从而获得分数**
攻防模式	线下赛，简称AWD（Attack With Defence）模式， 参赛队伍在网络空间互相攻击和防守，挖掘网络服务漏洞并攻击对方服务以得分，修补自身漏洞来防御以避免丢分。
渗透	受限于许多比赛解题模式的题目质量，解题模式渐渐衍生成综合渗透模式。 综合渗透更偏重于综合环境，通常一个目标IP或者目标网络，预设攻击路径，在不同路径点预置flag

CTF 解题模式

- Web-网络攻防
  - 常见漏洞:SQL注入、XSS、CSRF、文件包含、文件上传、代码审计、PHP弱类型
- **Reverse Engineering-逆向工程**
  - 工具平台、解题思路
- **Pwn-二进制漏洞利用**
  - 考察对二进制漏洞的挖掘和利用，需要对计算机操作系统底层有一定了解
- Crypto-密码攻击
  - 古典密码学：趣味性强，种类多
  - 现代密码学：安全性高，对算法理解的要求较高
- Misc-安全杂项

平台题目类型

- Reverse
  - phase_1: IDA/Ghidra usage
  - phase_2: Matrix transpose
- Pwn
  - phase_1: ret2code + call exit(0)

- 课程实验平台地址
- 用户注册码：`69766E65-6045-49F0-8D78-B10462AFD0C1`
- 用户名：学号

Request

```
pip install requests
```

- python基础学习 、 Request库

Web应用程序安全测试工具**Burp**

- 由 PortSwigger 开发，包括社区版和专业版
- 提供了全面的功能集，包括代理、爬虫、扫描器、Intruder、Repeater 等

```
https://portswigger.net/burp
```

Web应用程序安全测试工具**Yakit**

- 用于构建和管理Web应用程序中的 HTTP 代理的开源工具
- 专注于 HTTP 代理和流量拦截、修改，适合需要精细化控制 HTTP 请求和响应的场景。
- 不具备内建的自动化漏洞扫描功能，主要依赖于用户手动修改和分析 HTTP 流量

```
https://github.com/yaklang/yakit
```